



Cybersecurity clarity for growing companies.

Helix Health, Inc.

GRC Portfolio Executive Narrative

Prepared: 2026-06-24

Source: CISO Assistant v3.18.3 Community Edition

This portfolio presents a fictional healthcare SaaS persona designed to demonstrate IfeSec governance, risk, and compliance capabilities. All data is synthetic. No real patient or customer information is used.

Persona Overview

Helix Health, Inc. — Healthcare SaaS, BAA-covered PHI processing. 200 employees, 37 provider customers, 4 payer partners. HQ Boston MA.

200	37	4	Boston, MA
Employees	Provider Customers	Payer Partners	Headquarters

Perimeters in Scope

Ref	Perimeter	Lifecycle status	BAA-covered
a4ded43f...	Helix Provider Portal	Design	Indirect
663e69ad...	Helix Internal Infrastructure	Design	Indirect
ca576150...	Helix BAA-Scope PHI Processing System	Design	Yes

What Helix does

Helix Health operates a BAA-covered provider-payer data exchange platform. Provider customers send PHI through EHR connectors; Helix normalizes records to HL7 FHIR R4 and transmits them to payer partners. The platform runs on AWS with Auth0 authentication, Datadog observability, and Cloudflare edge protection.

Frameworks in Scope

Framework	Status in CISO Assistant	Rationale
HIPAA Security Rule	Loaded	Mapped via NIST SP-800-66 rev2; core PHI protection requirements
HDS v2.0	Loaded	French health data hosting certification for EU provider data
SOC 2 TSC (2022)	Loaded	Trust Services Criteria mapped to internal controls and policies
NIST CSF 2.0	Loaded	Risk scenarios and CSF functions aligned to Protect / Detect / Respond
ISO/IEC 27001:2022	Loaded	Mapped from SOC 2 TSC for international assurance
HITRUST CSF v11	Not in catalog	267 vendor libraries checked; custom JSON upload required if needed

Framework coverage notes

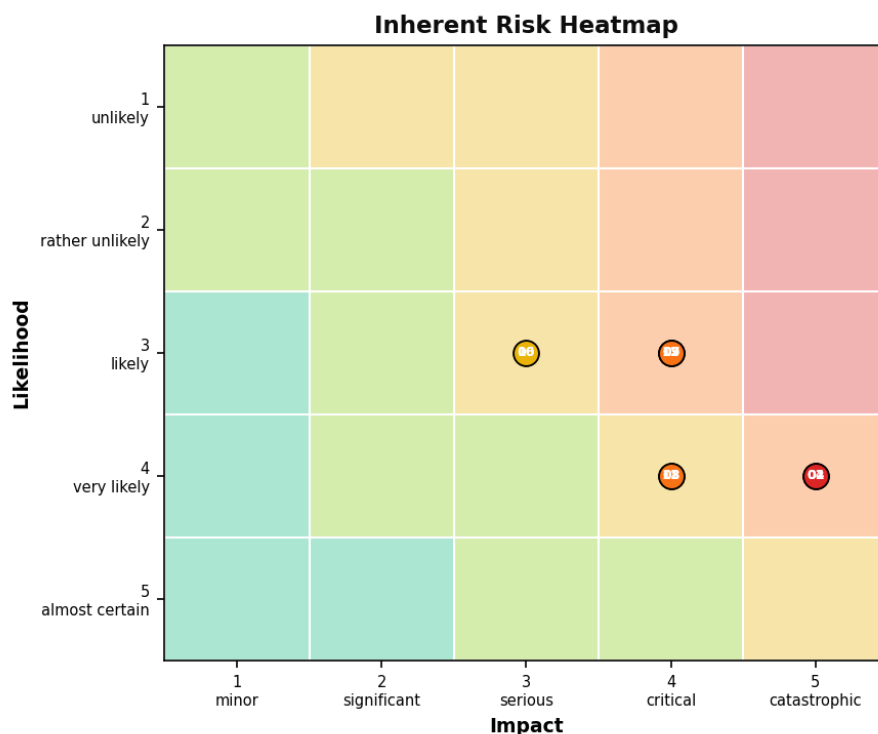
The Helix Health domain uses a single risk matrix, one risk assessment, 12 policies, and 10 vendor entities. HIPAA is the primary driver, supported by SOC 2 and HDS. HITRUST CSF v11 was requested but is not available in the community edition library catalog; a custom control upload would close the gap.

Control mapping count

Loaded frameworks: 33 | Risk scenarios: 12 | Policies: 12 | Vendors: 10

Risk Register Summary

Twelve risk scenarios were assessed in the Helix 5x5 ISO-27005 matrix. Inherent risk is dominated by ransomware, BAA vendor breach, and EHR connector compromise. Current and residual scores show strong mitigation posture with one exception.



Ref	Risk scenario	Treatment	Inherent	Current	Residual	Tolerance
HH-R-01	Ransomware encryption of PHI processing	Mitigate	5	2	2	YES
HH-R-02	BAA-covered vendor breach exposing PHI	Mitigate	5	2	2	YES
HH-R-03	Insider threat - privileged access misus	Mitigate	4	2	2	YES
HH-R-04	Provider EHR connector compromise (suppl	Mitigate	5	3	3	YES
HH-R-05	HIPAA breach notification failure (60-da	Mitigate	4	2	2	YES
HH-R-06	AWS region failure (us-east-1 outage)	Accept	3	2	2	YES
HH-R-07	Auth0 misconfiguration exposing patient	Mitigate	4	2	2	YES
HH-R-08	Inadequate BAAs with downstream vendors	Mitigate	4	2	2	YES
HH-R-09	Audit log tampering or loss	Mitigate	4	1	1	YES
HH-R-10	Phishing of clinical staff credentials	Mitigate	3	2	2	YES
HH-R-11	Insecure direct object reference in FHIR	Mitigate	4	2	2	YES
HH-R-12	Key compromise (KMS, code signing)	Mitigate	4	2	2	YES

Policy Library

Twelve active policies govern Helix Health. They are grouped into governance policy, operational process, and technical controls. All policies are active and at 100% documentation progress.

Distribution: 2 governance policy | 6 process | 4 technical

Ref	Policy	Category	Status	Progress
HH-POL-01	Information Security Policy	Policy	Active	100%
HH-POL-02	HIPAA Security Policies and Procedures	Process	Active	100%
HH-POL-03	Access Control & Privileged Access Policy	Technical	Active	100%
HH-POL-04	Business Associate Agreement (BAA) Policy	Policy	Active	100%
HH-POL-05	Breach Notification Policy (HIPAA 60-day rule)	Process	Active	100%
HH-POL-06	Incident Response Policy	Process	Active	100%
HH-POL-07	Vendor / Third-Party Risk Management Policy	Process	Active	100%
HH-POL-08	Risk Management Policy	Process	Active	100%
HH-POL-09	Encryption & Key Management Policy	Technical	Active	100%
HH-POL-10	Audit Logging & Monitoring Policy	Technical	Active	100%
HH-POL-11	Data Backup & Recovery Policy	Technical	Active	100%
HH-POL-12	Security Awareness & Acceptable Use Policy	Process	Active	100%

Policy architecture

Policy HH-POL-01 provides the governing mandate. HIPAA, vendor, incident, and breach policies establish process discipline. Access, encryption, logging, and backup policies define technical safeguards. Risk management and awareness policies close the governance loop.

Third-Party Risk Management

Ten vendors support Helix operations. Business Associate Agreements are required for any vendor that stores, processes, or transmits PHI. The table below reflects BAA status and PHI access as modeled in CISO Assistant.

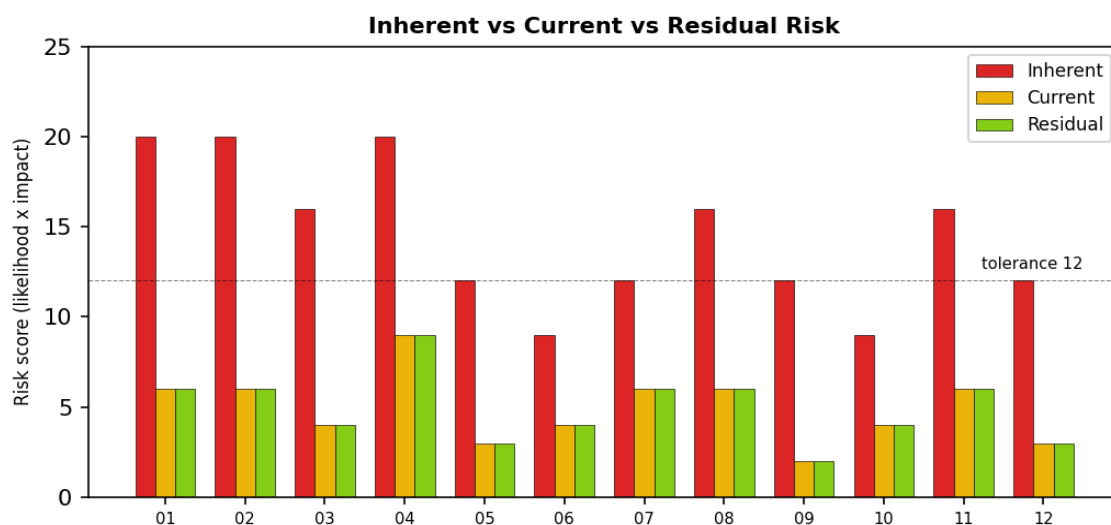
Ref	Vendor	Criticality	BAA in place	PHI access
HH-VEN-AMA	Amazon Web Services	Critical_no_baa	Yes	No
HH-VEN-DAT	Datadog	Critical_no_baa	Yes	No
HH-VEN-AUT	Auth0 (Okta CIC)	Critical_baa	Yes	Yes
HH-VEN-STR	Stripe	Low	No	No
HH-VEN-GIT	GitHub Enterprise	High	No	No
HH-VEN-GOO	Google Workspace	Medium	Yes	No
HH-VEN-PAG	PagerDuty	Medium	No	No
HH-VEN-CLO	Cloudflare	High	No	No
HH-VEN-SUM	Sumo Logic	High	No	No
HH-VEN-VAN	Vanta	Medium	Yes	No

Key vendor risks

Auth0 and AWS are the most sensitive: Auth0 handles patient portal authentication with BAA and PHI access; AWS hosts the production infrastructure. Stripe, GitHub, Cloudflare, PagerDuty, and Sumo Logic have no PHI access but remain high or medium criticality for availability and integrity. Risk HH-R-08 specifically addresses inadequate BAAs with downstream vendors.

Compliance Posture

Risk scores move from inherent exposure through current controls to residual target. The chart shows every Helix risk scenario. Most risks are now within tolerance; HH-R-04 (EHR connector compromise) remains medium at current and residual due to supply-chain dependency.



Metric	Value
Average inherent risk score	14.5
Average current risk score	4.9
Average residual risk score	4.9
Risks within tolerance	12/12
Very high / High inherent risks	6/12
Low / Very low residual risks	6/12

Next Steps & Portfolio Roadmap

The Helix Health GRC portfolio is staged for Phase 2 execution. Immediate priorities are closing residual risk exceptions, completing vendor BAA documentation, and building the compliance evidence pipeline.

Phase 2 — Control implementation

Harden EHR connector validation; deploy audit log forwarding to Datadog; complete BAAs for critical_baa vendors.

Phase 3 — Evidence collection

Run SOC 2 trust services evidence collection; map HIPAA administrative, physical, and technical safeguards to policies; produce HDS hosting attestation package.

Phase 4 — Audit readiness

Mock readiness review; gap remediation; prepare external auditor data room.

Phase 5 — Continuous monitoring

Implement control testing cadence, vendor reassessment cycle, and risk register quarterly review.

Known limitations

- HITRUST CSF v11 not in CISO Assistant v3.18.3 catalog (267 stored libraries available, none are HITRUST)
- Contracts visible in DB but API folder filter returns 0 (10 contracts created, all linked to entities via ORM)
- AtlasPay residuals not populated for 4/6 risks (out of scope for Helix)

Contact

IfeSec | ifeanyi@ifeanyi.digital | ifeanyi.digital